WHITE TEAM DOCUMENTATION

Team #14: Kansas State HackCats

Table of Contents

Summary of Public Services …….. 2

Network Architecture Notes ……. 2

Network Firewall ……. 3

Server Setup Notes ……. 5

Windows Machines …… 5

Linux Machines …….. 6

Active Directory Machine …….. 6

Ticketing Machine …….. 7

Admin Machine …….……..…….. 7

Management Machine …….. 8

Web ServerMachine ……. 9

Backup System Overview ……. 10

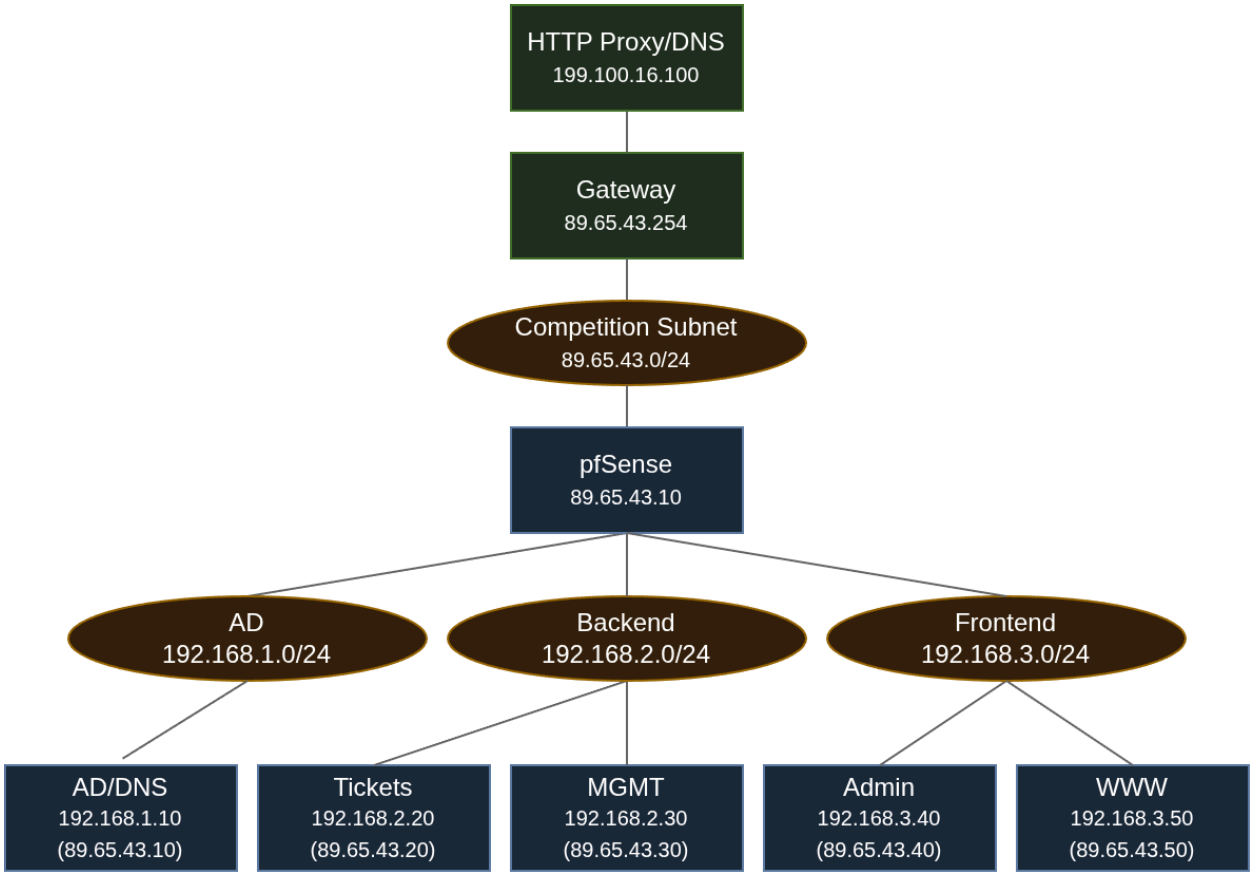
Summary of Public Services

The following ports and services are publically available:

Domain Name	Public IP	Port
ad.team14.isucdc.com	89.65.43.10	53,389,636,3389 (DNS,LDAP,LDAP/S,RDP)
tickets.team14.isucdc.com	89.65.43.20	3389,5000 (RDP,Ticket API)
mgmt.team14.isucdc.com	89.65.43.30	22,5000 (SSH/SFTP,Auth API)
admin.team14.isucdc.com	89.65.43.40	22,80 (SSH/SFTP,HTTP)
www.team14.isucdc.com	89.65.43.50	80,3389 (HTTP,RDP)

Network Architecture Notes

To better secure our machines, we decided to put our VMs behind a pfSense firewall. Using Virtual IPs on the Competition subnet, we expose public IPs which map to individual machines. The 1:1 mapping of IPs allows the services for each machine (i.e. DNS, RDP, SSH) to be made available while filtering all traffic through the firewall.



The network has been segmented into three sections, one for the Active Directory machine, along with partitions for the backend and frontend of the websites. Since pfSense can only filter traffic that crosses networks, separating systems across networks allows us to more closely monitor traffic to each segment of our infrastructure.

Network Firewall

As a blanket rule, each machine can only receive traffic on ports it has services for - as described in the table on page 2. Any traffic where a machine under the router attempts to reach out to a different machine on either port 22 or port 3389 is forbidden to prevent rudimentary reverse proxying attacks using SSH or RDP on standard ports. Zero-trust is enforced by ending each firewall rule list with a blanket deny rule.

Active Directory

In addition to the above rules, the Active Directory machine is allowed to send the following traffic:

- ICMP traffic
- UDP packets with a source or destination of port 53
- TCP packets with a source port of:
    - 389, for LDAP
    - 636, for LDAPS
    - 3389, for RDP

As for what is permitted, we are allowing egress packets with destination ports of 53, 80, 389, 443, 636, and 5000 so our rules do not reject traffic necessary for our services to function or IT employees to administer our network.

Backend

Similarly, the Backend machines can send traffic matching these rules in addition to the general ones above:

- ICMP packets
- UDP packets with a destination of port 53
- TCP packets with a source port of:
    - 22 where the destination port is not 22, for SSH
    - 3389 where the destination port is not 3389, for RDP
    - 5000, to respond to our websites

Frontend

The Backend machines can send traffic matching these rules in addition to the general ones:

- ICMP packets
- UDP packets with a destination of port 53
- TCP packets with a source port of:
    - 22 where the destination port is not 22, for SSH
    - 80, so our websites can respond to requests
    - 3389 where the destination port is not 3389, for RDP

Server Setup Notes

Windows Machines

OS Upgrades: Each windows server machine has been updated to the latest version of Windows with all available security patches. We found that crucial update services had been disabled on the Windows machines including the Windows Update Installer, Windows Modules Installer, and Background Intelligent Transfer Service. Enabling these services allowed for crucial security patches to be installed and remediated several critical vulnerabilities. Common software (E.G. browsers, etc.) has also been updated.

Wireshark: To provide further monitoring of network-based attacks, each windows machine has the Wireshark packet capture software installed. Wireshark will be recording the last rolling hour of network traffic to provide evidence and analysis opportunities in the event of a breach.

Firewall: Windows machines were configured using the Windows Defender Firewall. General rules are enforced using the Active Directory Group Policy. More information about specific rules for each machine is included below.

Password Policy: Password policy is enforced using the Active Directory Group Policy. Passwords are required to be 7 characters in length and contain numbers. After 5 incorrect login attempts, accounts are locked for 5 minutes.

Nessus Scans: The Essentials edition of Tenable Nessus was used to scan for potential vulnerabilities on each of the windows machines. General network scans, as well as malware and web application scans (where applicable) were performed.

Sysinternals suite: Sysinternals suite was installed on all machines. This Windows Suite has many useful tools for incident response and forensics. Some specific tools that help are Autoruns, Process Explorer, and Sysmon. Autoruns shows an overview of scripts and applications that run on startup. Process Explorer allows for more advanced process monitoring. Sysmon has detailed logging of processes on the computer.

Linux Machines

Updates: All Linux machines were updated using the native package manager to ensure the latest security patches and bug fixes were applied.

Firewall: Linux machines were configured using the natively installed firewall, *firewalld*. Only traffic through necessary ports is allowed. More information about specific rules for each machine is included below.

Scheduled Task Review: System and user cron jobs were reviewed to identify and remove any unauthorized, suspicious, or unnecessary scheduled tasks that could be used for persistence or automated attacks.

Active Directory Machine

The active directory machine is running Windows Server 2016. It hosts the active directory for the organization, allowing accounts and other machines to be managed from this single computer. All machines on the network are connected to the active directory machine, including Linux devices. By enforcing group policy rules on this machine, we can ensure that the other machines' functions are limited to what they need. Moreover, we can enforce user policies like password and software restrictions to further harden the network. This device is accessible through RDP.

This machine is also a DNS server, which using A records can map IP addresses to the domain with different subdomains to differentiate the systems.

This machine also houses the certificate authority which the Tickets machine uses to perform its functions.

Firewall Rules: Inbound and outbound traffic is blocked by default unless there is a rule allowing that traffic. Required ports for certificate authority, DNS, and active directory are open as well as LDAP (389), LDAPS (636), and RDP (3389) as required.

Hardening: Active directory is set to enforce a minimum password length and lockout policy on too many failed attempts. It is also set up to not use vulnerable protocols such as SMBv1 and other easily exploitable features like AutoPlay and NetBIOS.

Ticketing Machine

The Ticketing Machine is running Windows Server 2019. It hosts the backend for the ticketing system on port 5000 which allows administrators to sign and verify tickets. The device can be accessed by admins via RDP.

Firewall Rules: All inbound traffic is blocked unless it is on a required port. Traffic on ports 5000 (HTTP) and 3389 (RDP) is allowed.

Web Application Notes: The ticketing web application is a .NET 8 Web API written in C#. It relies on certificates from the Active Directory in order to process JSON payloads for signing and validating tickets. These utilities can be accessed from a Swagger dashboard available to admin via 89.65.43.20:5000/swagger and from the Management Backend.

Hardening: Two users with unnecessary administrative privileges (scrat and backdoor) were removed. Malwarebytes found a suspicious executable file, sus.exe, which was deleted.

Admin Machine

The Admin Machine is running Windows Server 2022. It hosts a web application on port 80 which allows administrators to log in and view/modify information on buses and trains. The device can be accessed by admins via RDP.

Firewall Rules: All inbound traffic is blocked unless it is on a required port. Traffic on ports 80 (HTTP) and 3389 (RDP) is allowed.

Web Application Notes: The Admin dashboard web application is written using Flask (Python). It is designed to allow admins to monitor and modify the status of buses and trains. New users can also be added from the dashboard.

The web application uses the Management server (mgmt.team14.isucdc.com) as a backend. Train/bus data is requested via HTTP requests to port 5000 and returned in JSON format. Updating the status of vehicles sends a POST request to the server. Credential validation is also done via the management server.

Hardening: Two users with unnecessary administrative privileges (scrat and nsa) were removed. Malwarebytes found a few suspicious executable files in the recycle bin which were deleted.

Management Machine

The Management Machine is running Alma Linux 8.4.0. This machine is the main transit management backend for the city and provides services to both user interfaces. It hosts a web application on port 5000 which handles user authentication, ticket payments, and fleet and route management for all of the city's transportation. Several other servers on the network utilize this service for verifying tickets, users, and train/bus information. The device can be accessed by admins via SSH.

Firewall Rules: All inbound traffic is blocked unless it is on a required port. Traffic on ports 5000 (HTTP) and 22 (SSH) is allowed.

Hardening: Management is set to enforce a minimum password length and lockout policy on too many failed attempts. The system was updated using the distribution package manager. Scheduled tasks were reviewed and ensured to not be malicious. A regular occurring backup system was implemented to provide a safe fallback in case of emergency.

On the web server side of things, there were several glaring flaws in the current code running on Management. Users were not actually being authenticated, and anyone could log in. This critical vulnerability was patched. Also, when creating a new account, the message 'user already exists' is sent if a username is already taken, which in general is not great security practice. This message was changed to be a more general error.

HTTP Interface: The Management machine is designed to work as a backend for both the public website and the internal admin dashboard. Authentication for user logins is done using LDAP, which is linked back to the Active Directory machine. Paths are available for requesting and updating the status of vehicles in the transportation network. Finally, the Ticketing machine is used to validate tickets purchased via the web interface through the management server.

Web Server Machine

The Web Server machine is running Alma Linux 9.7. This machine is the main host for the web application where users can purchase tickets, view maps, and manage their profile. This web application is hosted on port 80. This machine can be accessed by admins via SSH.

Firewall Rules: All inbound traffic is blocked, except for ports 5000 and 22.

Hardening: Steps were taken to ensure that malicious HTTP requests are not processed by the web application (sanitizing fields used in responses to avoid XSS in payment.py, auth.py, tickets.js, and map.js). These were found by auditing the web app using Snyk and performing a code review. Users who should not have admin permissions have been deprovisioned. The system was also updated using the distribution's package manager.

Backup System Overview

We have created an additional virtual machine for the purposes of fulfilling the backup requirements outlined in the scoring guide. The new machine is running a fresh install of Linux Ubuntu Server edition, and is statically assigned to the IP 89.65.43.60. Having a separate server for backups decreases the chances of data loss and helps ensure a clean backup process for our computer network. It ensures integrity of date even in the event of a full breach of a primary device.

Backups are performed using the Restic software, which was chosen due to its open-source nature and cross-platform compatibility. Snapshots are taken of a given directory and are securely pushed to the remote server via SFTP/SSH.

Windows: On the Windows machines (Admin, Active Directory, and Ticketing), the backup process is scheduled using the Windows Task Scheduler. A powershell script is scheduled to run every 30 minutes to initiate the backup.

Linux: On the Linux-based machines (Management and Website), the backup process is scheduled using Crontab. Similarly, the shell script is scheduled to execute every 30 minutes at the top and bottom of the hour.

Backups can be restored from the remote server using the Restic restore command. This can either be done with or without overwriting existing files, allowing flexibility for various different data issues that may arise.